

# *Report S9/L4*

## *Threat Hunting con*

## *Regole YARA*

Identificazione di malware APT tramite pattern matching su file system

---

|                         |                                                         |                  |                          |
|-------------------------|---------------------------------------------------------|------------------|--------------------------|
| <b>Studente:</b>        | Alessandro Porfirio                                     | <b>Docente:</b>  | ---                      |
| <b>Data:</b>            | 04/06/2026 YARA 64-bit                                  | <b>Ambiente:</b> | FlareVM (Windows 11 Pro) |
| <b>Tool utilizzato:</b> | (yara64.exe)                                            | <b>Target:</b>   | Flare_Incident_Drive\    |
| <b>Obiettivo:</b>       | Identificare file maligno camuffato tra file di sistema |                  |                          |

## 1. CONTESTO DELL'ESERCITAZIONE

### 1.1 Scenario

Nel contesto di questa esercitazione pratica ci troviamo nella situazione simulata di un analista di sicurezza che ha ricevuto un alert da un sistema di Threat Intelligence internazionale. Un gruppo APT (Advanced Persistent Threat) ha compromesso un sistema Windows e ha nascosto il proprio malware camuffandolo come un file di sistema legittimo (es. taskhost.exe, svchost.exe), posizionandolo all'interno della struttura di directory di Windows.

Il malware ha inoltre cambiato il proprio hash MD5/SHA256 per eludere i controlli basati su firma degli antivirus tradizionali. Cercarlo per nome o per hash sarebbe quindi impossibile.

### 1.2 Intelligence ricevuta

Il report di Threat Intelligence fornisce due Indicatori di Compromissione (IoC) specifici che caratterizzano questo gruppo APT:

|                         |                                                                           |
|-------------------------|---------------------------------------------------------------------------|
| <b>IoC #1 — Stringa</b> | AntiAV_Bypass_2026 (stringa di testo offuscata nel codice del malware)    |
| <b>IoC #2 — Bytes</b>   | { E2 9A 12 FF } (sequenza di byte esadecimali usata per memory injection) |
| <b>Logica</b>           | Il file e' maligno se contiene la stringa OPPURE la sequenza di byte      |

### 1.3 Perché YARA e non un antivirus

Gli antivirus tradizionali si basano su database di hash e firme digitali. Se il malware cambia anche solo un byte, il suo hash cambia completamente e l'antivirus non lo riconosce più. YARA invece opera in modo diverso: cerca **pattern comportamentali e strutturali** all'interno dei file — stringhe specifiche, sequenze di byte, combinazioni di caratteristiche. Questo approccio sopravvive alle varianti del malware, rendendolo lo strumento ideale per il Threat Hunting professionale.

## 2. PREPARAZIONE DELL'AMBIENTE

### 2.1 Ambiente di lavoro

L'esercitazione e' stata condotta sull'ambiente **FlareVM**, una distribuzione Windows specializzata per il malware analysis e il reverse engineering, sviluppata da Mandiant (Google). FlareVM include pre-installati tutti i tool necessari per l'analisi malware, tra cui YARA.

|                          |                                                          |
|--------------------------|----------------------------------------------------------|
| <b>Sistema operativo</b> | Windows 11 Pro — FlareVM                                 |
| <b>Tool YARA</b>         | yara64.exe (versione 64-bit, già disponibile in FlareVM) |
| <b>Editor testo</b>      | Blocco Note di Windows (Notepad)                         |
| <b>Directory lavoro</b>  | C:\Users\User\Desktop\                                   |
| <b>Target scansione</b>  | C:\Users\User\Desktop\Flare_Incident_Drive\              |

### 2.2 File di test scaricato

La cartella **Flare\_Incident\_Drive** e' stata scaricata dal link fornito durante l'esercitazione e decompresso sul Desktop. Essa simula il file system di un sistema Windows compromesso, contenendo centinaia di file tra cui il malware nascosto.

**Attenzione:** Il file maligno era posizionato all'interno di `Windows\System32\drivers\` — una directory critica del sistema operativo dove normalmente si trovano solo driver legittimi. Questa e' una tecnica di evasione reale utilizzata dai gruppi APT.

## 3. SCRITTURA DELLA REGOLA YARA

### 3.1 Struttura di una regola YARA

Una regola YARA e' composta da tre blocchi principali: **meta** (informazioni descrittive), **strings** (i pattern da cercare) e **condition** (la logica booleana che determina quando la regola scatta). Solo strings e condition sono obbligatori.

### 3.2 La regola sviluppata

La regola e' stata scritta direttamente nel Blocco Note di Windows, prestando attenzione a non usare virgolette curve (problema comune quando si copia da documenti PDF o Word). Il file e' stato salvato con estensione **.yar** selezionando 'Tutti i file (\*.\*)' nel dialogo di salvataggio per evitare che Windows aggiungesse automaticamente l'estensione .txt.

```
rule Caccia_APT_Malware
{
  meta:
    description = "Rileva malware APT con stringa e bytes specifici"
    author = "Studente Cybersecurity"
    date = "2026-06-04"
    threat = "APT - AntiAV Bypass 2026"

  strings:
    $stringa = "AntiAV_Bypass_2026" ascii wide nocase
    $bytes = { E2 9A 12 FF }

  condition:
    $stringa or $bytes
}
```

### 3.3 Spiegazione dettagliata della regola

|                  |                                                                                              |
|------------------|----------------------------------------------------------------------------------------------|
| <b>\$stringa</b> | Cerca la stringa 'AntiAV_Bypass_2026' nel file.                                              |
| <b>ascii</b>     | Cerca la stringa in formato ASCII (testo normale).                                           |
| <b>wide</b>      | Cerca anche in formato Unicode/UTF-16 (usato da molti eseguibili Windows).                   |
| <b>nocase</b>    | Case-insensitive: trova anche 'antav_bypass_2026' o 'ANTAV_BYPASS_2026'.                     |
| <b>\$bytes</b>   | Cerca la sequenza di byte esadecimali E2 9A 12 FF nel file binario.                          |
| <b>condition</b> | \$stringa or \$bytes: basta che UNO dei due pattern sia presente per far scattare l'allarme. |

**Osservazione:** I modificatori '**ascii wide nocase**' sono best practice per le stringhe in regole YARA: garantiscono che il pattern venga trovato indipendentemente dall'encoding e dalla capitalizzazione usata dal malware.

## 4. ESECUZIONE DELLA SCANSIONE

### 4.1 Apertura del prompt dei comandi

E' stato aperto il Prompt dei Comandi (CMD) di Windows e ci si e' spostati nella directory Desktop dove sono presenti sia la regola YARA che la cartella target:

```
cd C:\Users\User\Desktop
```

### 4.2 Comando di scansione lanciato

La scansione e' stata avviata con il flag **-r** (ricorsivo) per analizzare anche tutte le sottocartelle della directory Flare\_Incident\_Drive, che simula la struttura completa del file system Windows compromesso:

```
yara64.exe -r caccia_malware.yar C:\Users\User\Desktop\Flare_Incident_Drive
```

|                             |                                                        |
|-----------------------------|--------------------------------------------------------|
| <b>yara64.exe</b>           | L'eseguibile YARA a 64 bit, pre-installato in FlareVM. |
| <b>-r</b>                   | Modalita' ricorsiva: scansiona tutte le sottocartelle. |
| <b>caccia_malware.yar</b>   | La regola YARA che abbiamo scritto.                    |
| <b>Flare_Incident_Drive</b> | La cartella target contenente i file da analizzare.    |

### 4.3 Output del comando

YARA ha completato la scansione e ha restituito il seguente output sul terminale:

```
Caccia_APT_Malware  
C:\Users\User\Desktop\Flare_Incident_Drive\Windows\System32\drivers\updater_service.exe
```

**RISULTATO: Il file maligno identificato e' updater\_service.exe**

## 5. ANALISI DEI RISULTATI

### 5.1 Il file identificato

|                          |                                                                      |
|--------------------------|----------------------------------------------------------------------|
| <b>Nome file</b>         | updater_service.exe                                                  |
| <b>Percorso completo</b> | C:\Users\User\Desktop\Flare_Incident_Drive\Windows\System32\drivers\ |
| <b>Regola scattata</b>   | Caccia_APT_Malware                                                   |
| <b>Pattern rilevato</b>  | \$stringa ('AntiAV_Bypass_2026') oppure \$bytes ({ E2 9A 12 FF })    |

### 5.2 Analisi del comportamento evasivo

Il file maligno **updater\_service.exe** presenta caratteristiche tipiche delle tecniche di evasione usate dai gruppi APT reali:

**Nome ingannevole:** 'updater\_service.exe' imita il naming convention dei servizi Windows legittimi come 'wuauclt' (Windows Update) o altri update service. Un utente non esperto non lo noterebbe tra i file di sistema.

**Percorso strategico:** La posizione in System32\drivers\ e' scelta deliberatamente — e' una directory critica di Windows dove normalmente risiedono solo driver firmati da Microsoft. Un analista alle prime armi potrebbe ignorarla come 'sicuramente legittima'.

**Hash cambiato:** Come indicato nel brief dell'esercitazione, il malware ha modificato il proprio hash per eludere i controlli basati su firma. Un antivirus tradizionale non lo avrebbe rilevato.

### 5.3 Perché YARA lo ha trovato comunque

Nonostante le tecniche di evasione, la regola YARA ha identificato il file perché cercava caratteristiche **interne al codice** del malware, non attributi esterni come il nome o l'hash. La stringa AntiAV\_Bypass\_2026 o la sequenza di byte { E2 9A 12 FF } — entrambe caratteristiche specifiche di questo gruppo APT — erano presenti nel file e non erano state rimosse nonostante il cambio di hash e nome.

**Osservazione:** Questa è la forza di YARA: anche se il malware si rinomina, cambia hash o viene ricompilato parzialmente, se mantiene le sue funzionalità core (e quindi i pattern caratteristici), la regola lo troverà comunque.

```
FLARE-VM 04/06/2026 16:34:43,76
C:\Users\User\Desktop>yara64.exe -r caccia_malware.yar C:\Users\User\Desktop\Flare_Incident_Drive
Caccia_APT_Malware C:\Users\User\Desktop\Flare_Incident_Drive\Windows\System32\drivers\updater_service.exe

FLARE-VM 04/06/2026 16:35:52,51
C:\Users\User\Desktop>
```

## 6. PROBLEMI RISCONTRATI E RISOLUZIONE

### 6.1 Errore di sintassi nella prima regola

Durante la prima esercitazione (regola mia\_regola.yar), YARA ha restituito il seguente errore:

```
mia_regola.yar(1): error: syntax error, unexpected identifier
```

L'errore era causato da **virgolette curve** ( ' ' oppure " ") presenti nella regola copiata da un documento PDF/Word. Il Blocco Note di Windows aveva inserito automaticamente le virgolette tipografiche invece di quelle ASCII dritte, rendendo la sintassi YARA non valida.

### 6.2 Soluzione applicata

La soluzione è stata riscrivere la regola **manualmente da zero** nel Blocco Note, digitando le virgolette dalla tastiera invece di copiarle. Inoltre è stato verificato che il file fosse salvato con estensione **.yar** e non **.yar.txt** — problema comune quando non si seleziona 'Tutti i file (\*.\*)' nel dialogo di salvataggio.

|                         |                                                                               |
|-------------------------|-------------------------------------------------------------------------------|
| <b>Causa errore</b>     | Virgolette curve (") invece di virgolette ASCII dritte (")                    |
| <b>Causa secondaria</b> | Estensione .yar.txt invece di .yar (Blocco Note aggiunge .txt di default)     |
| <b>Soluzione</b>        | Riscrivere manualmente la regola + selezionare 'Tutti i file' nel salvataggio |

## 7. CONCLUSIONI E LEZIONI APPRESE

### 7.1 Obiettivo raggiunto

L'esercitazione ha raggiunto con successo il suo obiettivo: identificare un file maligno nascosto tra centinaia di file di sistema, in uno scenario realistico dove le tecniche di evasione tradizionali (cambio hash, nome legittimo, percorso critico) avrebbero reso impossibile l'individuazione tramite metodi convenzionali.

**File maligno identificato: `updater_service.exe` in `Windows\System32\drivers\`**

### 7.2 Competenze acquisite

**1. Struttura di una regola YARA** — Ho compreso come scrivere una regola completa con i blocchi meta, strings e condition, utilizzando i modificatori ascii, wide e nocase per massimizzare l'efficacia del rilevamento.

**2. Utilizzo di YARA da riga di comando** — Ho imparato a lanciare yara64.exe con il flag -r per scansioni ricorsive e a interpretare l'output per identificare il file maligno.

**3. Logica del Threat Hunting** — Ho compreso la differenza fondamentale tra approccio reattivo (antivirus basato su hash) e approccio proattivo (YARA basato su pattern), e perché quest'ultimo sia superiore contro minacce avanzate.

**4. Tecniche di evasione APT** — Ho osservato come un gruppo APT reale nasconde il proprio malware: nome legittimo, percorso critico, hash modificato.

**5. Troubleshooting** — Ho risolto autonomamente un errore di sintassi YARA identificandone la causa (virgolette curve) e applicando la correzione corretta.

### 7.3 Applicazioni reali

Le competenze acquisite in questa esercitazione sono direttamente applicabili in contesti professionali reali: un analista SOC utilizza regole YARA integrate nel SIEM per rilevare in automatico malware noti su migliaia di endpoint; un Incident Responder le usa durante un'indagine per scansionare rapidamente l'intero parco macchine aziendale alla ricerca di varianti di un malware identificato.

---

